

Buildweek_III_Kibana

Consegna

Obiettivi

In questo laboratorio, esaminerai i log di uno sfruttamento di vulnerabilità documentate HTTP e DNS.

- Parte 1 Investigare un Attacco di SQL Injection
- Parte 2 Investigare l'Esfiltrazione di Dati DNS

Contesto / Scenario

MySQL è un popolare database utilizzato da numerose applicazioni web. Sfortunatamente, l'SQL injection è una tecnica comune di hacking web. È una tecnica di iniezione di codice in cui un attaccante esegue istruzioni SQL malevole per controllare il server database di un'applicazione web.

I server dei nomi di dominio DNS) sono directory di nomi di dominio e traducono i nomi di dominio in indirizzi IP. Questo servizio può essere utilizzato per esfiltrare dati. Il personale di cybersecurity ha determinato che si è verificato un exploit e che dati contenenti PII (Personally Identifiable Information - Informazioni di Identificazione Personale) potrebbero essere stati esposti ad attori della minaccia.

In questo laboratorio, userai Kibana per investigare gli exploit per determinare i dati che sono stati esfiltrati usando HTTP e DNS durante gli attacchi.

Risorse Richieste

- Macchina virtuale Security Onion

Svolgimento

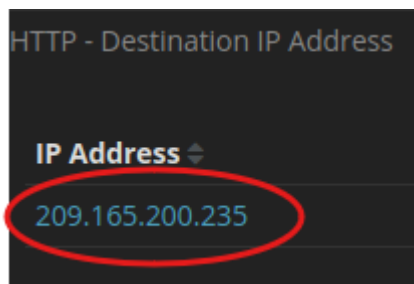
Qual è l'indirizzo IP sorgente?

L'indirizzo IP sorgente è 209.165.200.227.



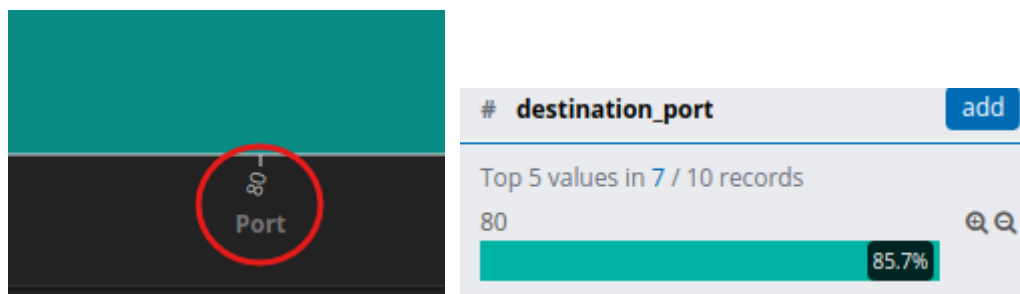
Qual è l'indirizzo IP destinazione?

L'indirizzo IP di destinazione è 209.165.200.235.



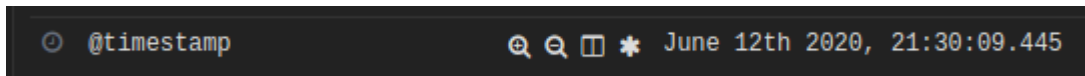
Qual è il numero di porta destinazione?

La porta di destinazione è la 80.



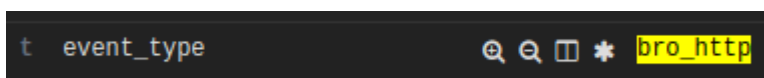
Qual è il timestamp del primo risultato?

Il timestamp per il primo log HTTP è **June 12th 2020, 21:30:09.445**



Qual è il tipo di evento?

L'event type è **bro_http**. "Bro" indica probabilmente che il log è stato processato da zeek in quanto "nomignolo" attribuito in passato a tale software.



Cosa è incluso nel campo message? Questi sono dettagli sulla richiesta HTTP GET fatta dal client al server. Concentrati specialmente sul campo uri nel testo del messaggio. Qual è il significato di queste informazioni?

Analizzando il campo del messaggio è possibile osservare una richiesta HTTP GET.

Dai campi visibili emergono elementi importanti; l'URI richiesto contiene una stringa che somiglia a un **attacco di tipo SQL injection** che sfrutta un input di **union select** con nomi di colonne come **credit_cards**, **password**.

Il metodo è **GET**, il codice di risposta è **200**, l'IP sorgente è **209.165.200.235** e il campo **tags** riporta **["HTTP::URI_Sqli"]** — segnale che un rilevatore ha già etichettato la richiesta come possibile **SQLi**.

Il significato di tali istruzioni indica per l'appunto un tentativo, da parte di un attaccante, di estrapolare informazioni dal database del webserver al quale viene effettuata la richiesta.



Cosa vedi più avanti nella trascrizione riguardo ai nomi utente? Fornisci alcuni esempi di nome utente, password e firma che sono stati esfiltrati.

Di seguito una schermata rappresentante Usernames, passwords e Signatures
esfiltrate tramite il comando `union select`:

DST: <p class="report-header">Results for . 5 records found.<p>

DST:

DST: 24

DST: Username=4444111122223333

DST:

DST: 17

DST: Password=745

DST:

DST: 22

DST: Signature=2012-03-01
<p>

DST:

DST: 24

DST: Username=7746536337776330

DST:

DST: 17

DST: Password=722

DST:

DST: 22

DST: Signature=2015-04-01
<p>

DST:

DST: 24

DST: Username=8242325748474749

DST:

DST: 17

DST: Password=461

DST:

DST: 22

DST: Signature=2016-03-01
<p>

DST:

DST: 24

DST: Username=7725653200487633

DST:

DST: 17

DST: Password=230

DST:

DST: 22

DST: Signature=2017-06-01
<p>

DST:

DST: 24

DST: Username=1234567812345678

DST:

DST: 17

DST: Password=627

DST:

DST: 22

DST: Signature=2018-11-01
<p>

DST:

DST: 3

DST: <p>

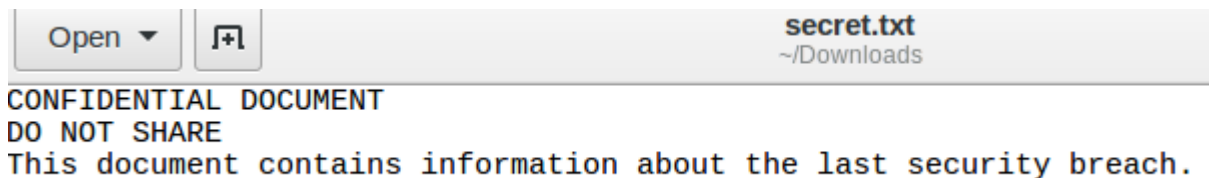
Registra gli indirizzi IP del client e del server DNS.

L'indirizzo IP del client è **192.168.0.11**, le source port utilizzate sono **45961**, **43404**, **54739** e **35738**; l'IP del server di destinazione è **209.165.200.235** e la porta target è sempre la **53**.

Time ▾	source_ip	source_port	destination_ip	destination_port
▶ June 12th 2020, 02:57:21.055	192.168.0.11	45961	209.165.200.235	53
▶ June 12th 2020, 02:57:21.052	192.168.0.11	43404	🔍 209.165.200.235	53
▶ June 12th 2020, 02:57:21.049	192.168.0.11	54739	209.165.200.235	53
▶ June 12th 2020, 02:57:21.041	192.168.0.11	35738	209.165.200.235	53

I sottodomini delle query DNS erano sottodomini? Se no, qual è il testo?

I sottodomini non erano reali sottodomini bensì rappresentavano un testo celato in formato **esadecimale** che è stato possibile convertire grazie a **xxd**:



I domini convertiti sono i seguenti:

697479206272656163682e0a.ns.example.com

666f726d61746966e2061626f757420746865206c617374207365637572.ns.example.com

484152450a5468697320646f63756d656e7420636f6e7461696e7320696e.ns.example.com

434f4e464944454e5449414c20444f43554d454e540a444f204e4f542053.ns.example.com

Cosa implica questo risultato riguardo a queste particolari richieste DNS?
Qual è il significato più ampio?

Le query non erano “sottodomini legittimi” ma **contenitori di dati** (QNAME-encoding). Ogni query ha trasportato una porzione del testo; ricombinandole nell’ordine cronologico si è ottenuto un file

Cosa potrebbe aver creato queste query DNS codificate e perché è stato scelto il DNS come mezzo per esfiltrare dati?

A creare tali query potrebbe essere stato un **attaccante** che ha avuto accesso alla macchina oppure un **malware** che è riuscito ad avviarsi all’interno della stessa al fine di trasmettere dati all’esterno celandoli sottoforma di richieste DNS.

Il DNS è scelto per i seguenti motivi pratici; essendo un servizio essenziale e quasi sempre **permesso in uscita**, le richieste sono piccole e facili da frammentare.

I firewall spesso non ispezionano il payload dei nomi DNS in profondità; il server autoritativo dell’attaccante riceve direttamente i QNAME e quindi può **ricostruire i dati**.

In breve c’è un’alta probabilità di riuscita nell’esfiltrare le informazioni senza rischiare di essere bloccati o notati.